# Lab 10 — Authorised assessment of your own lab

**Course:** Maxim Nyansa Cybersecurity Bootcamp, Ghana
**Trainee:** James Ackah Blay · Aiyinasi, Ghana
**Week:** 10 — Authorised vulnerability assessment
**Estimated time:** 6 hours
**Difficulty:** Advanced. The hard part is the scope and the report, not the number of tools.

**Tutor note.** Authorisation is the first task, not a footer. You may observe only `192.168.56.10` and `192.168.56.20` after the scope file is signed. Kali, if you build it, is `192.168.56.30` on the host-only adapter and is not a target. No bridged adapter. This guide has no exploit steps. A scan of any other network is out of scope even if you know how.

## 1. Learning objectives

| Objective | Job skill |
|---|---|
| Write a scope a client could hold you to | Professional vulnerability assessment |
| Run a narrow discovery against two hosts you own | Tool use inside a window, with notes |
| Detect that discovery in the manager | Blue team: the scan should not be invisible |
| Report findings without inventing any | The deliverable a customer remembers |

## 2. Prerequisites and setup

Wazuh from Week 3, addresses from Week 2. Kali is optional and only on host-only. NAT off during the window. `nmap` on the machine you will scan from, which may be the laptop or Kali.

```
nmap --version
```

OpenVAS or Greenbone Community Edition is optional. If you install it, follow the current official community guide. Set targets only after Task 1 is signed. This page does not repeat an install recipe that will go stale, and it does not list attack scripts.

## 3. Scenario

You have been asked to assess the lab as if it were a client's two servers. The client is you. The written scope is still required, because the habit matters more than the trust you have in yourself on a Friday night.

## 4. Tasks

### Task 1 — Scope gate

Edit `scope.csv`. Approver may be you, named, plus the date. In-scope addresses are only `.10` and `.20`.

```
python3 scope_gate.py scope.csv
```

> **You should now see** `scope_ok`. If the script exits with an error, do not start `nmap`. Fix the file.

### Task 2 — Discovery, narrowly

From the authorised machine, after `scope_ok`:

```
nmap -sn 192.168.56.10 192.168.56.20
nmap -sV -T2 -p 22,1514,1515,443,3389 192.168.56.10 192.168.56.20
```

`-sn` is a host check. `-sV` asks those ports what service they offer. `-T2` is slow on purpose. Do not add scripts, do not widen the port list to "all ports" unless your signed scope says so, and do not point either command at `192.168.56.0/24` if that would include a machine you did not list.

Save the text. Expected service names depend on what you installed. Write what you saw. If SSH is closed, that is a result.

### Task 3 — Optional Greenbone

If you run it, the target list is the two addresses only. Export the report into this folder. The finding count in your write-up must match the export. Zero findings is allowed. A finding you did not export is not allowed.

### Task 4 — Did the manager see it?

On the Wazuh dashboard, look for connections from the scanning host to `.10` or `.20` during the window. Quote one event or write "no matching event in the time window I searched". A scan your SIEM cannot see is a detection gap. Record it as a gap. Do not invent an alert to make the lab look finished.

### Task 5 — Report

Use `../vulnerability-assessment-report/report-template.md` and `../remediation-recommendations/recommendations.csv`. Status stays `not started` until Task 1 is signed and Task 2 has output. Severity labels: critical, high, medium, low, informational, each with a reason.

Phishing and malware notes in the Week 10 folders stay defensive. Do not add samples or lures to meet this lab.

## 5. Troubleshooting

| What you see | What it means |
|---|---|
| `scope_ok` is refused | Blank approver, or an address outside `.10` and `.20` |
| All hosts down | Wrong VirtualBox network, or the VMs are off |
| `nmap` not found | Install it on the machine inside the lab, not as a reason to scan from a campus network |
| Wazuh shows nothing | Time window, agent down, or the sensor does not log that flow. Write the gap |

## 6. Stretch task

Compare two findings, or one finding and one gap, and say which you would fix before the bootcamp ends. Tie the fix to a Week 3 or Week 8 control. If you have no findings, the stretch task is the detection gap from Task 4.

## 7. Evidence

- `scope.csv` with a real date.
- `nmap` text for the two commands.
- Optional Greenbone export.

- One Wazuh observation or a written gap.
- Report and remediation rows that match that evidence.

## 8. Reflection

1. What did the scope stop you from doing?
2. Which result surprised you because the service was open, or because it was closed?
3. What would you say to a client who wants you to “just look at” a third address?

## 9. Interview questions

1. What belongs in a rules-of-engagement page?
2. Why is a scanner finding not the same as a proven incident?
3. How do you prioritise two findings?
4. How would you notice an assessment in the SIEM?

## 10. Grading rubric

| Criterion | Exceeds | Meets | Not yet |
|---|---|---|---|
| Scope | Signed before the first scan, and the script agrees | Both addresses and a date | Scan first, scope after |
| Tools | Output matches the two commands, no extra targets | Output saved | A scan of a network you do not own |
| Detection | A quoted event or a clear gap | You looked | “The SIEM would have caught it” |
| Report | Findings match exports | Empty findings stated honestly | Invented CVEs |